Cumplimiento legal de Ahora Qué

Qué exige la ley, cómo la app lo cumple artículo por artículo y qué falta · Actualizado el 5 de noviembre de 2026 · Términos v1.2 · Privacidad v1.2

Documento de trabajo del proyecto. Es una guía orientativa, no asesoramiento legal: antes de un lanzamiento público conviene revisarlo con una persona abogada especializada en protección de datos y consumo. Cada requisito se presenta con cuatro datos: qué exige la norma, cómo lo cumple la app, dónde está en el proyecto y su estado (**Cumplido**, **Parcial**, **Pendiente** o **Del titular**: depende de una persona u organización, no de código).

1. Resumen

Ahora Qué trata datos personales de personas en Uruguay (cuenta, grupos, planes, chats, ubicación opcional, deudas, publicaciones) y ofrece una suscripción Premium, hoy en modo demostración. Por eso le aplican principalmente la **Ley 18.331** de Protección de Datos Personales y la **Ley 17.250** de Relaciones de Consumo.

Lo que cambió en esta actualización (5 de noviembre de 2026):

- **Aceptación documentada al registrarse** (art. 9): ahora se guarda la fecha, la versión de términos y de privacidad y la declaración del tutor en la tabla *Aceptaciones_Legales*, y términos y privacidad tienen casillas separadas.
- **Derecho de acceso** (art. 14): botón «Descargar mis datos» en el perfil, que entrega todos los datos de la persona en un archivo.
- **Política de privacidad al día**: lista todo lo que recibe el asistente de IA (incluida la memoria de Premium), el plazo de 5 días hábiles y el procedimiento de derechos, las protecciones de menores, la inscripción en la URCDP y la atribución a OpenStreetMap.
- **Arrepentimiento** (art. 16 de la Ley 17.250): el plazo se verificó en el texto de la ley, **cinco días hábiles**, y se informa así en los términos y antes de pagar.
- **Protocolos escritos** para vulneraciones de seguridad (aviso a la URCDP en 72 horas) y para atender derechos, con sus registros (*docs/legal/*).
- **Fallas de seguridad de la revisión de código corregidas**: sesiones que se cierran al cambiar la contraseña o borrar la cuenta, login que solo cuenta fallos, push solo a servicios conocidos y sin redirecciones, tope de mensajes al asistente, bloqueos de base de datos reales, verificación de integridad del mapa, enlaces de correo desde una URL fija, límites de tamaño y de largo de nombres.
- **Menores**: sus publicaciones son solo para amistades (forzado en el servidor) y se guarda su declaración de tutor.
- **Limpieza programada** de registros temporales y borrado de chats de grupo a los 14 días.

Lo que todavía depende de la persona titular del proyecto (ver sección 6): definir el titular real con RUT y domicilio y cargarlo en las variables *PROVEEDOR_**; inscribir la base en la URCDP; revisar las condiciones de tratamiento de datos de cada proveedor; confirmar regiones; rotar claves si el archivo .env se compartió; revisión final con asesoría legal.

2. Marco normativo

- **Ley 18.331 (2008)**: protección de datos personales y acción de habeas data. Reglamentada por el Decreto 414/009.
- **Ley 19.670 (2018), artículos 37 a 40**: alcance territorial, responsabilidad proactiva, comunicación de vulneraciones de seguridad y delegado de protección de datos. Reglamentados por el Decreto 64/020.
- **Ley 17.250 (2000)**: relaciones de consumo, incluida la contratación a distancia y el derecho de arrepentimiento (art. 16). El Decreto 167/2021 reglamenta el deber de información en el comercio electrónico.

- **Licencias de terceros**: OpenStreetMap (ODbL) y condiciones de uso de Groq, Brevo, Supabase, Render y Cloudflare.
- **Autoridad de control**: URCDP (Unidad Reguladora y de Control de Datos Personales). La ley uruguaya se aplica a quien ofrece servicios a personas ubicadas en Uruguay aunque el responsable esté en el exterior.

3.Cómo cumple la app cada artículo y cada ley

Esta es la tabla central del documento. Para cada artículo: qué exige, cómo lo cumple la aplicación, en qué archivos está y en qué estado se encuentra.

Norma y artículo	Qué exige	Cómo lo cumple la app	Dónde está	Estado
Ley 18.331, art. 4 y 18 Datos sensibles	Consentimiento expreso y por escrito para datos como salud, origen racial, opinión política, religión o vida sexual; nadie está obligado a darlos.	Ningún formulario pide datos sensibles. Los términos y el asistente advierten no escribirlos. Riesgo residual en textos libres (publicaciones, descripción): se mitiga con reportes y moderación.	templates/terminos.html, templates/_chatbot_panel.html, routes/social.py (reportes y moderación)	**Cumplido**
Ley 18.331, art. 6 Legalidad	Inscribir la base de datos en el Registro de Bases de Datos Personales de la URCDP.	La app ya muestra el número de inscripción en la política de privacidad cuando se carga la variable *PROVEEDOR_URCDP* (hoy figura «completar»). La inscripción en sí es un trámite en gub.uy/urcdp.	services/legal_info.py, templates/privacidad.html (sección 1)	**Del titular**
Ley 18.331, art. 7 Veracidad	Datos veraces, adecuados y no excesivos.	Se pide solo lo necesario (sin teléfono, documento ni dirección). La fecha de nacimiento se usa solo para verificar la edad. Nombre, usuario y correo se validan en el servidor. La persona corrige sus datos desde el perfil.	templates/register.html, routes/profile.py, services/validaciones.py	**Cumplido**
Ley 18.331, art. 8 Finalidad	No usar los datos para fines incompatibles; eliminarlos cuando la finalidad se cumple.	La política lista cada finalidad. Eliminar la cuenta borra toda la información asociada (borrado en cascada verificado). Limpieza programada diaria de confirmaciones vencidas e intentos de login viejos; los chats de grupo se borran a los 14 días.	templates/privacidad.html, migraciones/eliminar_cuenta.sql, services/mantenimiento.py, services/chat_service.py	**Cumplido**
Ley 18.331, art. 9 Consentimiento previo, informado y documentado	Consentimiento libre, previo, expreso, informado y documentado; si se presta junto con otras declaraciones, debe figurar de forma expresa y destacada.	El registro tiene tres casillas propias: términos, privacidad con consentimiento expreso (incluye el envío a IA en el exterior) y, entre 13 y 17 años, autorización del tutor. Todas se validan en el servidor. Se guarda la constancia (fecha, versión de términos y de privacidad, tutor) al confirmar el correo. En Premium, la aceptación tiene casilla propia y se guarda con fecha y versión.	templates/register.html, routes/auth.py, services/auth_service.py, migraciones/aceptaciones_legales.sql, services/legal_info.py, migraciones/premium_historial.sql	**Cumplido**
Ley 18.331, art. 10 Seguridad de los datos	Medidas técnicas y organizativas necesarias para garantizar seguridad y confidencialidad.	Ver sección 5. Contraseñas y tokens con hash, chats del asistente y cuentas bancarias cifrados (AES-256-GCM), HTTPS, protección CSRF, límites de intentos, tope de mensajes al asistente, sesiones revocables, validación de subidas, SRI en el mapa, enlaces de correo desde URL fija.	app.py, database.py, services/seguridad.py, services/crypto_service.py, services/push_service.py	**Parcial**

Norma y artículo	Qué exige	Cómo lo cumple la app	Dónde está	Estado
Ley 18.331, art. 11 Reserva	Quienes intervienen en el tratamiento guardan secreto.	La base solo es accesible desde la aplicación (RLS activada sin políticas públicas, credenciales en variables de entorno); los chats del asistente están cifrados; la moderación queda limitada a cuentas configuradas. Falta dejar por escrito quién accede a los datos y un compromiso de confidencialidad del equipo.	migraciones/*.sql (RLS), routes/social.py	**Del titular**
Ley 18.331, art. 12 y Decreto 64/020 Responsabilidad proactiva	Adoptar medidas apropiadas para cumplir la ley y poder demostrarlo.	Este documento, minimización de datos desde el diseño, cifrado, historial de aceptaciones, textos legales versionados, protocolos escritos y registros de incidentes y de derechos.	docs/legal/PROTOCOLO-VULNERACIONES-Y-DERECHOS.md, este documento	**Cumplido**
Ley 18.331, art. 13 Derecho de información	Informar al recolectar: finalidad, destinatarios, responsable y domicilio, si responder es obligatorio u opcional, consecuencias de no hacerlo y cómo ejercer los derechos.	La política es pública y se enlaza desde el registro. Indica datos, finalidades, proveedores (con el detalle de lo que recibe el asistente), transferencias, plazos de conservación, derechos y contacto. Los datos obligatorios y opcionales están diferenciados. Muestra razón social, RUT, domicilio e inscripción desde variables; faltan los datos reales.	templates/privacidad.html, templates/terminos.html, services/legal_info.py	**Parcial**
Ley 18.331, art. 14 Derecho de acceso (Decreto 414/009: 5 días hábiles)	Acceso gratuito (en general cada 6 meses), con respuesta en 5 días hábiles.	«Descargar mis datos» en el perfil entrega cuenta, grupos, planes, mensajes de chat propios, publicaciones, comentarios, amistades, deudas, constancia de aceptación e historial de Premium en un archivo JSON, sin contraseña ni datos de otras personas. Para lo demás, pedido por correo con respuesta en 5 días hábiles, publicada en la política.	routes/profile.py, services/datos_personales.py, templates/perfil.html, templates/privacidad.html (sección 10)	**Cumplido**
Ley 18.331, art. 15 Rectificación, actualización, inclusión y supresión	Poder corregir, actualizar, incluir y suprimir los datos.	Rectificación y actualización desde el perfil (nombre, usuario, descripción, contraseña, cuenta bancaria). Supresión con «Eliminar mi cuenta», que borra todo. El resto, por correo con procedimiento escrito (registrar, verificar identidad, responder, archivar).	routes/profile.py, services/auth_service.py, docs/legal/PROTOCOLO-VULNERACIONES-Y-DERECHOS.md	**Cumplido**
Ley 18.331, art. 16 Impugnación de valoraciones personales	Poder impugnar decisiones basadas solo en tratamientos automatizados.	No se toman decisiones automatizadas sobre las personas: la IA solo sugiere planes y decide la persona. Se declara en la política.	templates/privacidad.html (sección 10)	**Cumplido**
Ley 18.331, art. 37 y 38 Acción de habeas data	Si no se responde o la respuesta es insuficiente, la persona puede iniciar la acción.	La política informa el derecho a reclamar ante la URCDP y a iniciar la acción; el protocolo de derechos prevé archivar pedido y respuesta.	templates/privacidad.html, docs/legal/	**Cumplido**
Ley 18.331, art. 23 Transferencias internacionales	No transferir a países sin nivel adecuado salvo excepciones (por ejemplo, consentimiento del titular) o autorización de la URCDP.	La política lista proveedores y países. El registro tiene una casilla propia de consentimiento expreso a las transferencias. Falta confirmar la región real de cada proveedor, comprobarla en el listado vigente de la URCDP y revisar los contratos de tratamiento.	templates/privacidad.html (secciones 5 y 6), templates/register.html	**Parcial**

Norma y artículo	Qué exige	Cómo lo cumple la app	Dónde está	Estado
Ley 18.331 (criterio prudente) Menores de edad	La ley no fija edad mínima expresa en lo verificado; se aplica una regla prudente.	Edad mínima 13; entre 13 y 17, declaración del tutor obligatoria y guardada; Premium solo para mayores de 18 (servidor). Las publicaciones de menores son solo para amistades (forzado en el servidor), la ubicación es opcional por plan y no hay mensajes privados fuera de los grupos. Queda el perfil público visible a otras cuentas.	routes/auth.py, services/social_service.py, templates/social.html, services/legal_info.py	**Parcial**
Ley 19.670, art. 37 Alcance territorial	Aplica a quien ofrece servicios a personas en Uruguay aunque el responsable esté en el exterior.	Se asume y se aplica la ley uruguaya; los términos no la excluyen.	templates/terminos.html	**Cumplido**
Ley 19.670, art. 38 y Decreto 64/020 Vulneraciones de seguridad	Comunicar a la URCDP dentro de 72 horas, informar a las personas afectadas si es significativo, e informe final.	Protocolo escrito de seis pasos (detectar, contener y rotar claves, evaluar, notificar a la URCDP, informar a las personas, cerrar) y registro de incidentes. La política lo declara. Falta que lo apruebe el titular.	docs/legal/PROTOCOLO-VULNERACIONES-Y-DERECHOS.md, templates/privacidad.html (sección 12)	**Cumplido**
Ley 19.670, art. 39 y 40; Decreto 64/020 (arts. 6 y 10 a 15) Evaluación de impacto y delegado	Evaluación de impacto en ciertos supuestos y designación de delegado en otros.	Análisis preliminar: no se identificó ninguno de los supuestos (no hay datos sensibles como eje del servicio, ni perfilado automatizado de personas ni tratamiento a gran escala). Debe confirmarse con la guía de evaluación de impacto de la URCDP y asesoría.	este documento	**Del titular**
Ley 17.250, información previa Decreto 167/2021	Información suficiente, clara, veraz y en español antes de pagar.	Bloque «Condiciones de Premium» antes del pago: quién vende, precio final en pesos con IVA, renovación automática, cancelación, arrepentimiento y edad mínima; sección propia en los términos. Los datos del vendedor son marcadores hasta que haya titular.	templates/_premium_legal.html, templates/terminos.html (sección 8), services/legal_info.py	**Parcial**
Ley 17.250, honestidad de la oferta	No engañar con precios o servicios que no existen.	Cartel DEMO visible, precios marcados como ejemplo, formulario de pago que descarta los datos de tarjeta en el navegador y activación bloqueada en producción salvo que se habilite la demo.	templates/_premium_demo.html, routes/suscripcion.py	**Cumplido**
Ley 17.250, renovación y cancelación	Consentimiento expreso a la renovación automática y cancelación sencilla.	Casilla de aceptación obligatoria validada en el servidor; cancelación con un clic desde «Tu suscripción», registrada en el historial.	routes/suscripcion.py, templates/premium_pagar.html, templates/suscripcion.html	**Cumplido**
Ley 17.250, art. 16 Arrepentimiento	Rescindir el contrato a distancia dentro de **cinco días hábiles** desde la formalización o la entrega, comunicándolo por medio fehaciente; si el servicio se prestó en parte, se paga lo ejecutado.	Los términos y las condiciones previas al pago informan el plazo de 5 días hábiles (verificado en el texto de la ley), la comunicación por escrito al contacto y el pago solo de la parte prestada.	templates/terminos.html, templates/_premium_legal.html	**Cumplido**

Norma y artículo	Qué exige	Cómo lo cumple la app	Dónde está	Estado
Ley 17.250, medios de pago	Proteger los datos de pago.	La app no recibe ni guarda números de tarjeta ni códigos; los campos del formulario no se envían al servidor. Con cobros reales se usaría un procesador de pagos habilitado.	templates/premium_pagar.html, services/pago_mock.py	**Parcial**
Ley 17.250, comprobante y capacidad	Comprobante al contratar; contratar solo con capacidad.	Comprobante por correo (marcado como demostración); solo mayores de 18 años, verificado en el servidor con la fecha de nacimiento. Para cobros reales hace falta un titular con RUT en DGI, IVA y facturación electrónica.	services/suscripcion_service.py, routes/suscripcion.py	**Parcial**
Licencia ODbL (OpenStreetMap)	Atribución visible: © colaboradores de OpenStreetMap.	La atribución está en el pie de todas las páginas, en la política de privacidad y en el control de atribución del mapa (antes estaba desactivado).	templates/base.html, templates/privacidad.html, static/mapa_plan.js	**Cumplido**
Condiciones de proveedores Groq, Brevo, Supabase, Render, Cloudflare	Respetar sus condiciones y tener sus contratos de tratamiento de datos.	La política declara quién recibe qué (incluido el contexto que recibe el asistente). Falta revisar y guardar copia de las condiciones de tratamiento de cada proveedor.	templates/privacidad.html (sección 5)	**Del titular**
Cookies	Informar el uso de cookies.	Solo técnicas (sesión y guía de bienvenida) y almacenamiento local de tema; sin analítica ni publicidad. Declaradas en la política (sección 8).	templates/privacidad.html, services/guia_nueva.py	**Cumplido**

4. Qué datos trata la app y para qué

- **Cuenta** (obligatorio): nombre, correo, usuario, fecha de nacimiento y contraseña (solo su hash). Finalidad: crear la cuenta, verificar la edad y operar el servicio.
- **Constancia de aceptación**: fecha, versión de términos y privacidad y declaración del tutor. Finalidad: poder demostrar el consentimiento.
- **Actividad**: grupos, planes, votos, mensajes de chat (14 días), publicaciones, comentarios, reacciones y amistades.
- **Ubicación** (opcional): solo si la persona la comparte en un plan; se guarda únicamente la última.
- **Deudas** y, opcionalmente, banco y número de cuenta (cifrado).
- **Asistente de IA**: mensajes de la persona; en grupo, además contexto agregado del grupo (presupuesto, días ocupados, cantidades de votos, ideas rechazadas, planes mejor y peor puntuados); con Premium, la descripción del perfil como memoria. Todo viaja a Groq (EE. UU.) para responder; los chats se guardan cifrados.
- **Seguridad y soporte**: intentos de inicio de sesión (se borran), mensajes de contacto (llegan por correo) y suscripciones de notificaciones.
- **Premium**: historial de altas y bajas con fecha, frecuencia y versión de condiciones; los datos de tarjeta nunca pasan por la app.

5. Medidas de seguridad (artículo 10)

Implementadas

- Contraseñas con hash; tokens de confirmación y recuperación guardados con hash, de un solo uso y con vencimiento; registro con doble confirmación por correo.

- Cifrado de las conversaciones del asistente y del número de cuenta bancaria (AES-256-GCM).
- Consultas SQL parametrizadas; renderizado seguro en el navegador (sin HTML inyectable en chats ni en el markdown del asistente).
- Protección contra CSRF por verificación de origen, cookies SameSite, cabeceras de seguridad y validación de imágenes subidas; tope de 1,5 MB por pedido (respuesta 413).
- RLS activada en las tablas, sin políticas públicas. Borrado de cuenta completo y verificado.
- **Nuevo:** el login cuenta solo los intentos fallidos y un acceso correcto los borra; los límites de intentos siguen en recuperación de contraseña y contacto; tope de 40 mensajes por hora por persona al asistente.
- **Nuevo:** las sesiones se cierran si cambia la contraseña o se borra la cuenta (una huella de la contraseña viaja en la cookie y se compara con la base).
- **Nuevo:** las suscripciones push solo se aceptan hacia servidores de Google (FCM), Mozilla, Apple y Microsoft (WNS), y el envío no sigue redirecciones (evita que el servidor llame a direcciones arbitrarias).
- **Nuevo:** los bloqueos *FOR UPDATE* de encuestas y deudas ahora corren dentro de una transacción; antes, en modo autocommit, soltaban el bloqueo al instante.
- **Nuevo:** verificación de integridad (SRI) en la librería del mapa; enlaces de los correos armados desde una URL pública configurada (*PUBLIC_BASE_URL*) y no desde el host de la petición; nombre y descripción de grupo con largo máximo y saneados antes de llegar al asistente; un usuario no puede llamarse como el correo de otra persona; guardar o borrar un plan exige tener acceso a él.

Pendientes y límites conocidos

- La política de seguridad de contenido (CSP) sigue siendo mínima porque la app usa scripts en línea; el siguiente paso es moverlos a archivos y agregar *script-src*.
- El límite de login por identificador no puede ser por dirección IP detrás del proxy actual: quien conozca un usuario aún puede forzar un bloqueo temporal de esa cuenta con intentos fallidos.
- Archivo *.env* con claves reales incluido en un zip: rotar las claves (base de datos, sesión, Groq, Brevo, VAPID) si se compartió. La clave maestra de chats no se rota sin antes volver a cifrar los datos.
- Variable *PUBLIC_BASE_URL* por definir en Render para que los enlaces de correo salgan de una URL fija.

6. Lo que depende de la persona titular

Estos puntos no se resuelven con código: requieren una decisión o un trámite de la persona o empresa que figure como titular.

1. Definir el titular (persona o empresa) y cargar *PROVEEDOR_RAZON_SOCIAL*, *PROVEEDOR_RUT* y *PROVEEDOR_DOMICILIO* en Render. La app los muestra en la política y en las condiciones de Premium.
2. Inscribir la base de datos en la URCDP (gub.uy/urcdp) y cargar el número en *PROVEEDOR_URCDP*.
3. Confirmar la región real de cada proveedor, comprobarla en el listado vigente de la URCDP y revisar y guardar copia de sus condiciones de tratamiento de datos.
4. Aprobar el protocolo de vulneraciones y designar quién lo ejecuta; dejar por escrito quién accede a los datos y un compromiso de confidencialidad.
5. Rotar las claves si el archivo .env se compartió y definir *PUBLIC_BASE_URL* en Render.
6. Revisión final de todos los textos con asesoría legal (en especial la regla de edad mínima, las transferencias y, para cobros reales, DGI, IVA y facturación electrónica).

7. Plan de acción y estado

Prioridad	Acción	Estado
Alta	Definir el titular con RUT y domicilio y cargar PROVEEDOR_*	**Del titular**
Alta	Inscribir la base en la URCDP	**Del titular**

Prioridad	Acción	Estado
Alta	Guardar la aceptación del registro (fecha, versión, tutor) en la base	**Cumplido**
Alta	Redactar el protocolo de vulneraciones (falta aprobarlo)	**Cumplido**
Alta	Corregir las fallas de seguridad de la sección 5	**Cumplido**
Alta	Resolver transferencias internacionales: consentimiento específico, región y contratos	**Parcial**
Media	Publicar el plazo de 5 días hábiles y el procedimiento de derechos	**Cumplido**
Media	Protección de menores (publicaciones solo a amistades, declaración guardada)	**Parcial**
Media	Atribución a OpenStreetMap	**Cumplido**
Media	Alinear la política con lo que recibe el asistente	**Cumplido**
Media	Revisar si corresponde evaluación de impacto o delegado	**Del titular**
Media	Confirmar el plazo del artículo 16 de la Ley 17.250 (5 días hábiles)	**Cumplido**
Baja	Descarga automática de datos personales	**Cumplido**
Baja	Limpieza programada de registros temporales	**Cumplido**
Baja	Revisión final de todos los textos con asesoría legal	**Del titular**

8. Registros que conviene mantener

- Versiones publicadas de los términos y de la política, con fecha (*services/legal_info.py*).
- Constancia de aceptación de cada persona al registrarse (*Aceptaciones_Legales*) y en Premium (*Premium_Historial*).
- Registro de solicitudes de derechos y de sus respuestas, y registro de incidentes de seguridad y de comunicaciones a la URCDP (plantillas en *docs/legal/PROTOCOLO-VULNERACIONES-Y-DERECHOS.md*).
- Copias de las condiciones de tratamiento de datos de cada proveedor.
- Inscripción en la URCDP y autorizaciones de transferencia, si corresponden.
- Este documento, actualizado cada vez que cambie una función que toque datos o pagos.

9. Fuentes

- Ley 18.331: https://www.impo.com.uy/bases/leyes/18331-2008
- Decreto 414/009: https://impo.com.uy/bases/decretos/414-2009
- Decreto 64/020: https://impo.com.uy/bases/decretos/64-2020
- Ley 17.250 (artículo 16 verificado el 5 de noviembre de 2026): https://www.impo.com.uy/bases/leyes-originales/17250-2000
- Decreto 167/2021: https://impo.com.uy/bases/decretos/167-2021
- URCDP (inscripción, guías y listados de países adecuados): https://www.gub.uy/unidad-reguladora-control-datos-personales
- OpenStreetMap (licencia ODbL): https://www.openstreetmap.org/copyright